

Simplifying Security

Kathleen Moriarty
Chief Technology Officer

March 2022

Simplifying Security

Abstract

Scale is the most important consideration as industry transforms information security and assurance across our supply chains. The transition to zero trust presents us with an opportunity to embrace network and security architectures that scale by centralizing the configuration and management of our systems, devices, and software. A focus on improving scale has the potential to not only improve security for organizations of all sizes but to also reduce the ongoing lack of qualified cybersecurity professionals. Scalable zero trust architectures can help to fully automate assurance with expected network and asset configurations, policies, and measurements. The approach minimizes individual security management tasks for both small organizations that may lack the necessary resources to achieve essential cyber hygiene as well as for large organizations that manage tens of thousands of systems. This paper proposes solutions to automate the foundations of a security program and thereby help organizations of any size to transition to zero trust at scale.

Introduction

Simplifying security has always been a long-time goal. But it's been difficult to achieve historically. Simplification goes well beyond automation, which is oftentimes touted as the "silver bullet" by marketers in the industry today. In this context, simplifying security is focused on reducing the number of system-level security actions and responsibilities distributed to administrators in an organization. But simplification is not reducing what is done to secure systems; it's about shifting it to the supplying vendor and changing how it's done while maintaining an emphasis on scale.¹

Small organizations and large organizations face the same challenges. Whether it's a lack of resources needed to run a tool, customize a configuration over a small number of systems, apply a standard security configuration, or run a verification tool on thousands of systems, it's an obstacle that introduces even greater levels of complexity. Current security architectures require organizations to hire multiple resources to actively manage multiple products, customize the security configuration of individual systems, and maintain management infrastructure for multiple products that touch all systems on the network. These architectures have resulted in the unintended consequence of creating a shortage of 3.5 million qualified cybersecurity professionals. The more distributed we make IT infrastructures, the more we create a need for qualified people to secure these disparate components. This is unscalable and unsustainable over the long-term.

Even now, the struggle is apparent in how the digital threat landscape has changed. Attacks are near-constant, and they often target prevalent weaknesses that arise in the absence of both built-in security measures and a dynamic security posture. In order to reduce the attack surface, how we deploy and manage security must change, as even the largest organizations are overburdened and unable to adequately manage the security of

systems. There is also a clear gap for smaller, under-resourced organizations that are unable to hire professionals.

This change must take two factors into account. First, it must continue to hold the concept of "shift left" as synonymous with built-in security that's already available at the time of purchase. Second, it's important to consider architectural patterns that scale for ongoing security management. This includes conformance to policies that maintain products' security baselines and reduce the success rate of attacks.

As security management simplifies and vendors build in security controls at scale, organizations will require that transparency is maintained for key operational management functions such as change control and audit. These elements play increasingly important roles, as an expected set of policies and configurations (i.e. allow-lists) can more easily detect and prevent unexpected and unwanted changes. It is possible to have this shift rely on a set of experts centralized at the vendor to improve scale with careful planning.

Built-in security using allow-lists is a desired end state to improve security and detection, but unless it is architected to simplify security management, the landscape will become more complex and require even more resources to manage environments. The concepts of zero trust, built-in security, and allow-lists are all central requirements of the U.S. Executive Order 14028² as well as other international directives such as the European Union Network and Information Security Directive (NIS),³ NIS2, and the Digital Operational Resiliency Act (DORA) legislative proposal.⁴

After years of research and demonstrated results, it is clear that zero-architectures (ZTA) aid in reducing attacker dwell time—the time that an attacker remains on a network or within

¹ "Transforming Information Security: Optimizing Five Concurrent Trends to Reduce Resource Drain", K. Moriarty, Emerald Publishing, Ltd., July 2020.

² Executive Order on Improving the Nation's Cybersecurity, May 12, 2021. <https://www.whitehouse.gov/briefing-room/presidential-actions/2021/05/12/executive-order-on-improving-the-nations-cybersecurity/>

³ Directive EU 2016/1148 of the European Parliament and of the Council of 6 July 2016. Official Journal of the European Union. <https://eur-lex.europa.eu/eli/dir/2016/1148/oj>

⁴ Regulation of the European Parliament and of the Council on Digital Operational Resiliency for the Financial Sector and amending regulations (EC) No 1060/2009, (EU) No 648/2012, (EU) No 600/2014, (EU) No 909/2014. September 24, 2020. <https://eur-lex.europa.eu/eli/dir/2016/1148/oj>

an application without being detected.⁵ ZTAs do this by detecting attacks earlier in the Lockheed Martin Kill Chain™.⁶ Along these same lines, the NIST Special Publication 800-207 Zero Trust⁷ tenets set forth granular controls at the component or even application module level to enable detection. No component trusts another component, so each must be built as secure as possible.

This pervasive zero trust architecture requires the following:

- The verification of every module before it connects to another, which ensures that it meets an allow-list of expected configurations and controls
- The verification of authentication and authorization between components
- The application of encryption for data at rest and in transit
- The dynamic verification of controls, configurations, and authentication
- The logging of everything, providing transparency and enabling detection

These foundational zero trust tenets aid in the ability to detect anything unexpected in real-time.

Transformation from Today to Tomorrow

Scale is the most important consideration as the industry transforms and works to reduce the attack surface across our supply chains. After all, our supply chains cover businesses of all sizes in a range of industries, including those supporting critical infrastructure. Improved scale for managing information security would have a direct impact on all under-resourced organizations, including U.S. State, Local, Tribal, and Territorial (SLTT) organizations.

In the challenge to secure networks today, organizations have to purchase multiple products in addition to the base products that support business needs. Each of these security products require management from human employees. Due to the complexity of the product, they may require the attention of a full-time employee. This isn't the case with built-in security and allow-list approaches that consider scale, however. What's more, these security efforts raise costs for attackers, making it more difficult for them to succeed with an intrusion.

This raises the question: How do we shift left, build in security, and create patterns that better scale management, reducing the need for distributed management?

Using policy and measurement sets that align to standards is one way to shift the management of security back to the vendor

while enabling simplified automation. Using this method, a smaller set of analysts set forth the expected policy and measurement values to a given standard (e.g. NIST SP 800-193) instead of implementing a distributed approach where all organizations using a product are individually responsible for that level of configuration. Organizations can enable this approach through a technology called "attestation," and reporting can scale through "remote attestations" that assert compliance to a set of policies, configurations, and/or measurements. (The remote attestation in this case is to an attestation set. Attestations and remote attestations are assured using cryptography.)

Advances in technology that have enabled use of attestations to a root of trust⁸ and remote attestation sets create an opportunity to simplify security's foundational building blocks. Figure 1 provides a model of how we as an industry can replicate the pattern established in trusted infrastructure up the stack, adding remote attestation sets to enable reporting with assurance.

Attestations from a root of trust can result in very large numbers of verifications for settings and measurements. From a hardware perspective, a trusted relationship for a virtual trusted platform module (vTPM) can be available for use if the hardware TPM does not scale to meet the demands of verification for any set of policies. It is likely that the industry could see remote attestation used to report on compliance to a set of policies in the near future, with the initial candidate most likely being an assertion of firmware assurance to NIST SP 800-193 on Firmware Resiliency. Most hardware and firmware vendors provide an assurance of trusted firmware today. The only remaining part is to convey that the set of policies is met with a remote attestation⁹ for each system at boot and at run-time. Conveying individual attestations used to assess compliance to NIST SP 800-193 would require too much data, but a single attestation including cryptographic evidence of compliance could/should be used to achieve scale.

The following sections detail how this method could be used to better scale security management and shift the industry towards allow-list approaches. Not only would this simplify management at scale and help close the deficit of information security professionals, but it would also present an opportunity to deprecate some add-on security products. The outlined approach will take time for the industry to adopt, but the transition is necessary due to a lack of resources and an increased cadence of successful wide-reaching attacks (e.g. attacks targeting customers of software or managed service providers). The timelines for the federal government requiring zero trust¹⁰ by the end of Fiscal Year (FY) 2024 will accelerate progress as will adoption of zero trust by industry actors in both products

⁵ "Where Does Zero Trust Begin and Why is it Important?" Center for Internet Security Blog. <https://www.cisecurity.org/insights/blog/where-does-zero-trust-begin-and-why-is-it-important> Note: Additional references included in blog to explain and back assertion.

⁶ Lockheed Martin Cyber KillChain. <https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html>

⁷ National Institute of Standards and Technology (NIST) Special Publication (SP) 800-207, "Zero Trust Architecture"; 2020. <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207.pdf>

⁸ Remote Attestations Enabling Posture Assessment for Automated GRC. Center for Internet Security Blog. 2021. <https://www.cisecurity.org/insights/blog/remote-attestation-enabling-posture-assessment-for-automated-grc>

⁹ Internet Draft, Scalable Remote Attestations for Systems, Containers, and Applications. K. Moriarty and A. Fontes. December 2021. <https://datatracker.ietf.org/doc/draft-moriarty-attestationsets/>

¹⁰ Office of Management and Budget (OMB) Memo 22-09. United States White House. January 26, 2022. <https://www.whitehouse.gov/wp-content/uploads/2022/01/M-22-09.pdf>

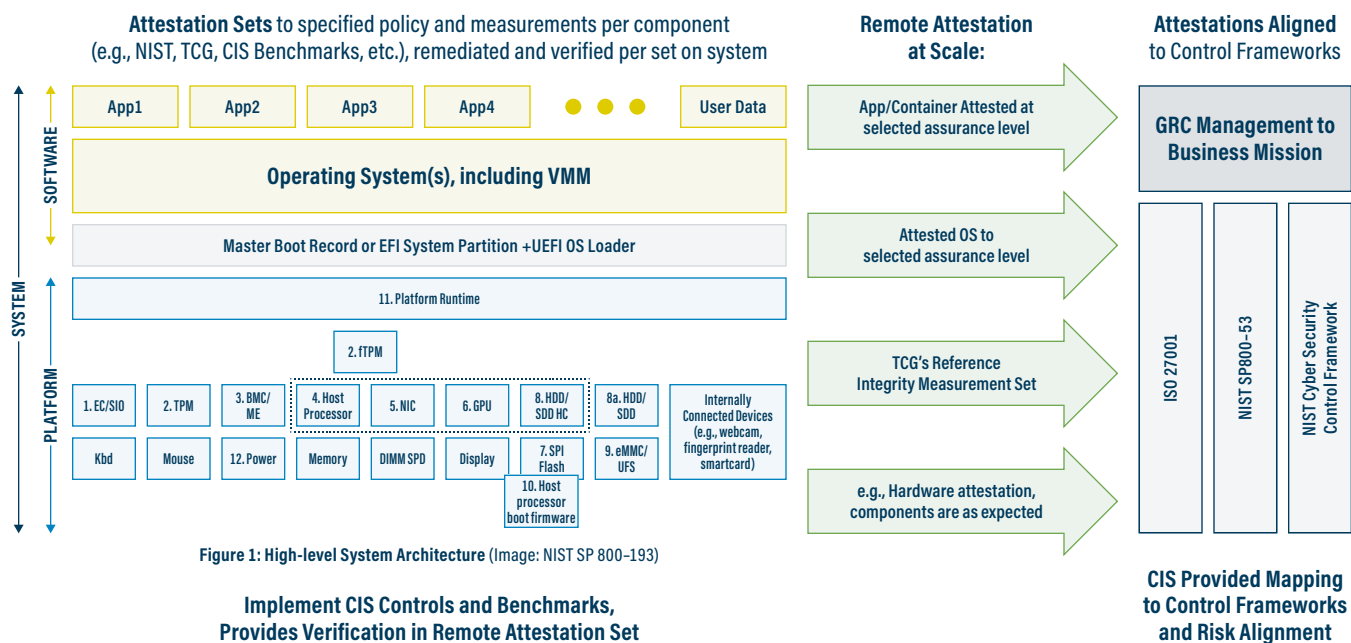


Figure 1: High-level System Architecture (Image: NIST SP 800-193)

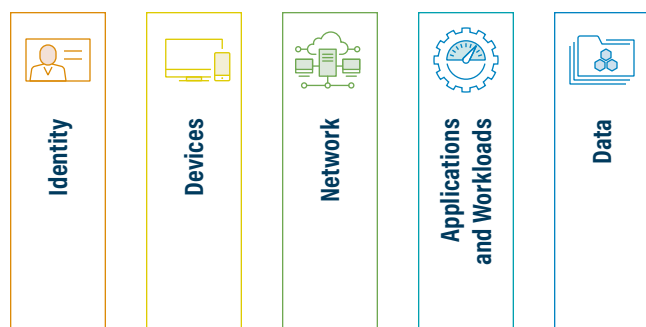
Figure 1. Remote Attestation to Standards

and deployments. Several large vendors understand that this simplification is necessary for their own zero-trust journeys, and they are working towards these goals with the idea that doing so will benefit all organizations.

Foundational Building Blocks

The foundational elements of any security program include asset inventory and assurance to policy requirements. Assets include devices, systems, applications, data, and people. Ultimately, organizations need to have an inventory of assets and their states to assess and measure their security program.

The U.S. Office of Management and Budget (OMB)¹¹ has called out these security practices as foundational not only to a zero-trust journey but also to any security program. The pillars named by OMB provide a tangible way to track and assess assets within a security program. They include:



Essential cyber hygiene includes these foundational building blocks that have long been part of every security control framework (e.g. CIS Critical Security Controls, ISO27001, NIST SP 800-53). As an example, the CIS Critical Security Controls account for Asset Inventory in CIS Control 1, Software Inventory in CIS Control 2, Data Protection in CIS Control 3, and Secure Configuration of Assets and Software in CIS Control 4. Traditionally, add-on products that require additional management resources have been necessary to gauge the effectiveness of these security measures and controls. As the industry adopts zero trust and “shifts left” to built-in security, however, we have the opportunity to remove, or at least reduce, this resource requirement.

In recent years, an important example of shifting left with scalability emerged when most hardware vendors began providing assurance of trusted infrastructure. From the time of boot, the firmware and BIOS are assured by each vendor to established configuration settings and measurements that align to a single standard on Firmware Resiliency documented in NIST SP 800-193.¹² Within each system at boot and within many at runtime, verifications take place to assure configuration settings and to confirm that firmware measurements meet a set of “golden values.” If a value is not matching an allow-list as expected, a process may stop or restart, indicating that something is wrong and that the system is not in a trusted state. Attestation technology then records results of each verification in a cryptographically protected log. This has become possible in recent years because of advances in capabilities

¹¹ Office of Management and Budget (OMB) Memo 22-09. United States White House. January 26, 2022. <https://www.whitehouse.gov/wp-content/uploads/2022/01/M-22-09.pdf>

¹² National Institute of Standards and Technology (NIST) Special Publication (SP) 800-193. Firmware Resiliency. 20XX. <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-193.pdf>

with the trusted platform module (TPM)¹³ hardware chip on every platform. Each vendor develops the necessary checks to comply with NIST SP 800-193 and ensures that the policy, configuration settings, and measurements are met without distributed management requirements at each organization. In other words, this is a clear example of an architectural pattern that scales and that can be replicated.

How does this tie into the automation of essential cyber hygiene or foundational controls?

Each system that provides assurance from a root of trust at boot and runtime has a set of logs that can be used to verify this assertion. A cryptographically signed remote attestation¹⁴ can be used to report a summary finding on the set of attestations¹⁵ that demonstrates the system meets expectations, providing an assurance that it is trusted as defined in NIST SP 800-193. This remote attestation could be used for building an asset inventory, and the hardware or firmware vendor would be responsible for providing it, creating an assurance of trust.

Attestation from a root of trust is now intrinsic to traditional infrastructure (e.g. on-premise servers, storage systems for data centers, remote user systems) as well as hosted environments (e.g. hyperscalers and Infrastructure-as-a-Service providers). It's therefore possible to propose a method of automating foundational controls using architectural patterns that scale to simplify security management while we adopt zero trust. As a preview, Figure 2 outlines the foundational control areas possible for automation at scale that will enable industry to “shift left” and scale to meet the needs of organizations of all sizes, including those that lack resources.

Asset Inventory

Systems that support a trusted boot process and replicate this process at runtime contain cryptographically protected logs attesting to the expected state. This information can facilitate remote attestation, particularly for reporting on the asset and the state of its hardware, firmware, and BIOS both at boot and at runtime. In shifting to remote attestation to provide this information, the originating vendor builds in an asset inventory capability in a simplified and automated way. This approach shifts left the configuration and assessment responsibilities, creating a fully integrated asset inventory capability. As such, a small number of analysts at the vendor can deploy policies and measurement expectations. They can also provide the ability to attest and verify to those values at purchase and at times of update, supporting the capability throughout the product lifecycle. The process of enabling attestation and programming where assets should send remote attestations could simplify asset management systems. This method might

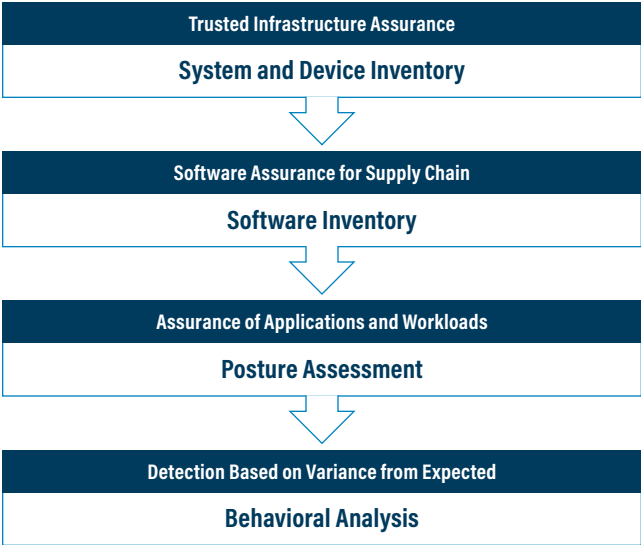


Figure 2. Automating and Simplifying Cyber Essentials

also give organizations that lack asset management systems a path forward for adding the capability without complicated management requirements.

Software Assurance

A Software Bill of Materials (SBOM) is gaining traction in the wake of Executive Order 14028, which requires detailed manifests on software purchased by the U.S. federal government. This initial step of having a manifest to describe software and its contents will help significantly when vulnerabilities like Log4Shell appear in libraries (e.g. Log4j) included in numerous software applications. Organizations can use ad SBOMs to find where these libraries exist on their network and to patch them accordingly. To clarify, SBOMs in themselves do not simplify management for organizations, although they do help to highlight in-use software and libraries that teams can map to known vulnerabilities for remediation.

The SBOM standard allows for a vendor to select one of a few formats when creating the software manifest as defined in the “Minimum Elements for a Software Bill of Materials (SBOM)”¹⁶ document. The variance in permitted formats may be cumbersome for some organizations. It may be necessary to use a translation engine when multiple formats are permitted, as a result.

Additionally, Executive Order 14028 calls for a shift to allow-lists. If the industry approaches this transition using architectural patterns for management that scale, it could make tremendous progress towards reducing the surface attack for all organizations.

13 TPM 2.0 Library. Trusted Computing Group. <https://trustedcomputinggroup.org/resource/tpm-library-specification/>

14 Internet Draft, Entity Attestation Token, L. Lundblade, G. Mandyam, and J. O'Donoghue. November 2021. <https://datatracker.ietf.org/doc/draft-ietf-rats-eat/>

15 Internet Draft, Scalable Remote Attestations for Systems, Containers, and Applications. K. Moriarty and A. Fontes. December 2021. <https://datatracker.ietf.org/doc/draft-moriarty-attestationsets/>

16 “The Minimum Elements For a Software Bill of Materials (SBOM)”. United States Department of Commerce. July 2021. https://www.ntia.doc.gov/files/ntia/publications/sbom_minimum_elements_report.pdf

But how do we establish efficient patterns of security management with this change?

Every organization will have a unique set of allowed applications and libraries supporting those applications. The manifests may also be described in one of the following three formats: Software Package Data Exchange (SPDX),¹⁷ CycloneDX,¹⁸ and Software Identification¹⁹ (SWID) tags. Larger organizations will likely have the resources to manage the set of allowed applications and supporting libraries. They might accomplish this through the use of application programming interfaces (APIs) and a management system. These systems will likely normalize the formats to enable consistency for organizational management. Even so, other organizations will require a more automated method to manage allowed software that scales. Automation alone will not suffice in cases where organizations lack necessary recourses.

SBOMs are commonly signed with a Code Signing certificate. The certificate and associated key may be a short-lived code signing certificate²⁰ that uses the Automated Certificate Management Environment (ACME)²¹ protocol or software like Sig-Store.²² But it's not necessary for them to be so. The certificate and key could instead use longer certificate lifetimes, following principles in place for public key infrastructure (PKI). Here, the root certificate used in the issuance process for a PKI code signing certificate and key (short- or long-lived) used for signing SBOMs are deemed trusted. Trusting a root certificate in this way would mirror the method used for root of trust with web sites, but it could be more tightly managed to a root of trust for a particular software vendor as opposed to the Certificate Authority vendor's root of trust that might be in use by any large number of vendors. (See chapter 7.4, Transforming Information Security.²³) Major vendors already follow this practice for app stores with varying management practices where tight management has helped to restrict the installation of software that has not been fully vetted.

Alternatively, attestation sets could involve a vendor providing approved sets of SBOMs that are compared against reported remote attestations from the software on managed systems. The vendor set of approved SBOMs in an attestation set might include some software that isn't in use, but it can still deem that software safe upon release. The vendor might update the list of approved SBOMs periodically, allowing organizations to compare this list to the current state of their systems as they automatically report the software on their systems using remote attestations. In both models, a shift left occurs where the providing vendor offers an inventory of software as well as

a method to allow-list expected software. This shift is critical, as an allow-list approach enables real-time detection if unexpected software appears. It also obviates the need for anti-virus solutions and some indicators of compromise (IoCs). Ideally, vendors can use a single allow-list approach for SBOMs. Doing so will help to achieve a simpler management model.

In shifting to use of the code signing certificates or root certificates to establish an allow-list of applications, the potential problems associated with the use of multiple formats to represent the manifests no longer factor toward this goal. The use of certificates or root certificates to establish trust is also proven to scale. This helps to manage or avoid using previous lessons learned.

Policy and Configuration Assurance

Policy and configuration assurance, otherwise known as posture assessment, is an important step in achieving essential cyber hygiene. If your systems and software are configured to known secure benchmarks or standards, it is less likely that an attack against those systems will be successful. If they are also assured to this set of configuration requirements and measurements, detection can shift to an allow-list approach where it becomes easier to detect anomalies or anything unexpected.

Configuration to a known good state for an operating system, application, or device requires a knowledgeable trusted resource such as a CIS Benchmark²⁴ or DISA Security Technical Implementation Guide.²⁵ In some cases, it is possible to purchase systems that are certified to meet specification requirements. Achieving assurance to the specification requirements over time currently requires the use of an add-on tool that may require management resources unless automated in a cloud setting as part of a service. Even then, the tools and standards (e.g. Security Content Automation Protocol (SCAP)) used for automating assessments are often cumbersome, requiring configuration and management by every implementing organization. These challenges have limited adoption due to the need for skilled resources to manage and maintain these posture assessment tools.

There is a way to use these standards that's similar to assessing trusted infrastructure, however. This method would involve querying the posture assessment values using these standards, programming them by the asset (e.g. software, workload, container) vendor, and comparing them to a set of expected "golden values" using the verification process that is part of attestation using a TPM. In this way, organizations could fully

¹⁷ Software Package Data Exchange (SPDX). The Linux Foundation. <https://spdx.dev/>

¹⁸ CycloneDX. OWASP. <https://cyclonedx.org/>

¹⁹ ISO/IEC 19770-2:2015. Information Technology – IT asset management – Part 2: Software Identification Tag. 2015. <https://www.iso.org/standard/65666.html>

²⁰ Internet Draft, ACME End User Client and Code Signing Certificates. K. Moriarty. September 2021. <https://datatracker.ietf.org/doc/draft-ietf-acme-client/>

²¹ RFC8555. Automatic Certificate Management Environment (ACME). R. Barnes, J. Hoffman-Andrews, D. McCarthy, and J. Kasten. March 2019. <https://datatracker.ietf.org/doc/html/rfc8555>

²² SigStore. The Linux Foundation. <https://www.sigstore.dev/>

²³ "Transforming Information Security: Optimizing Five Concurrent Trends to Reduce Resource Drain", K. Moriarty. Emerald Publishing Ltd., July 2020.

²⁴ CIS Benchmark. Center for Internet Security. <https://www.cisecurity.org/cis-benchmarks/>

²⁵ Security Technical Implementation Guide (STIG). Defense Information Systems Agency (DISA). <https://public.cyber.mil/stigs/>

automate their posture assessment and thereby reduce or eliminate the need for in-house expertise. The method (e.g. SCAP) for reviewing the configuration setting or measurement does not matter as much as being able to perform the assessment in a way that is assured cryptographically.

While it may not be possible to assess all recommendations in a CIS Benchmark or other specification using attestations of each configuration setting or measurement, this method could help to automate much of the assessment in a way that scales. CIS Benchmarks and other hardening guides typically have options that are selected during the time of configuration to meet a business need. The variances in setting options could result in some products needing to meet certain levels in a CIS Benchmark for their assessments over time. Here, the providing vendor could automate assurance to the attestation set, which may be a CIS Benchmark or a defined level of CIS Benchmark.

This assurance method would help organizations to achieve essential cyber hygiene through the products they purchase, not through the internal expertise that they have on staff. This level of automation, when done in a way that scales, would have a substantial impact on reducing the resources needed to manage information security globally. Since systems, applications, and devices would meet an expected set of policies, configuration settings, and measurements, detecting anomalies would become as simple as detecting a setting or measurement that does not meet an expected value.

Behavioral Analysis

Attackers use software already present on systems to conduct attacks and achieve their attack objectives. The shift to allow-lists won't stop all attacks, but it will increase the difficulty of an attacker remaining undetected, especially when coupled with a pervasive adoption of zero trust tenets. If there is verification of identity and an assurance level coupled with encryption and logging, it is far easier to detect the unexpected and prevent further access to a new component or module.

Once the building blocks are in place and an organization better understands what is expected for their infrastructure, software, and configurations, they are able to define expected behaviors more precisely. In simple systems such as Internet of Things (IoT) devices, this may be as straightforward as defining a Manufacturer Usage Description (MUD)²⁶ profile for a device where only expected behaviors are permitted. This approach used in MUD may also be possible at a per-module level. On larger systems where the interactions between modules and components are more complex, a need for advanced analytics to detect unexpected behaviors may remain.

Sophisticated attackers aim to evade detection for as long as possible. In the process, they maintain variations within expected ranges for some measurements of allowed "golden values" with attestation verification. Detection of unexpected patterns within allowed ranges is an important use-case for tools that rely on artificial intelligence to monitor telemetry resulting from the verification process with local attestation. If using attestation sets, the remote attestation will have a complete trail of evidence to ensure transparency as well as auditability to the values that comprise a given standard for comparison (e.g. NIST SP 800-193, CIS Kubernetes Benchmark). However, this evidence will end up in integrity-protected logs on the host due to the volume of attestations that's required to provide assurance to a number of such standards and benchmarks on every system. As such, the evolution of endpoint products may shift to detect variance from expected values and behavioral patterns that could indicate an attack within expected values.

The standards and benchmarks measured cross the full stack of a system. As a result, it may not be possible to perform this analytic function from the providing vendor in full. A combination of assessment results may require analysis, with target products potentially originating from multiple vendors. Taken together, these assessments can help to stop a particular attack, with layered analytics offering a larger view into the extent of a compromise. In other words, existing endpoint products are already adapting to detection capabilities based on unexpected findings from allow-list models. The use of attestation result data is a logical addition to this suite of products. In particular, it can further support the endpoint as the industry more fully implements encryption on internal networks, a condition which U.S. federal agencies are expected to meet by the end of FY 2024.

The proposed building blocks enable transparency and consistency of controls and configurations, thus simplifying behavioral detection capabilities. Further analysis can lend additional assistance as the industry progresses toward built-in security at scale.

Resource Reduction and Product Elimination

There is a clear reduction in resource requirements with built-in security using architectural patterns that scale. In this model, a smaller number of centralized experts can produce a large impact on distributed assets. Additionally, changing to allow-lists from widely deployed deny-lists can reduce or eliminate the need for add-on security products.

In the case of asset management, there are numerous discovery mechanisms in use today, many of which use passive detection to identify an asset. While accuracy has improved over time, the possibility of a false positive exists either due

26 RFC8250, Manufacturer Usage Description (MUD), E. Lear, R. Droms, D. Romascanu. March 2019. <https://datatracker.ietf.org/doc/html/rfc8250>

to error or purposeful mis-advertisements to hide information on an asset. If an asset does not support reporting to attest to the level of trust for an asset, organizations may need existing technologies for discovery. However, remote attestation yields higher assurance on the assets and the state of those assets wherever it occurs. The current set of products use a management approach that is out of reach for numerous organizations due to their purchase and maintenance costs as well as the lack of available information security professionals.

Products that perform network endpoint assessment (NEA)²⁷ provide assurance to asset inventory. However, the complexity of these products continues to be a hurdle to deployment. Built-in assurance to expected policies using attestation replace the need for this type of add-on solution as was provided by NEA.

In the case of software and workload assessments, with a shift to management of an expected set of software, anything not on the allow-list constitutes an exception. For software, this eliminates the need of anti-virus software that utilizes signature matching against a deny-list of software or other detection capabilities such as IoCs. The latter point is particularly important, as very few organizations have the capacity to consume IoCs in threat feeds and deploy IoCs out for detection within their environment. An allow-list of software and expected configurations is smaller, better defined, more predictable, and more stable than a deny-list of IoCs. Similarly, intrusion prevention has already shifted to behavioral detection. Many intrusion prevention systems have adopted an allow-list approach and have moved to the endpoint due to an increase in encrypted traffic on the network. With management enabled and eased by the providing vendor, an allow-list capability for software and posture assessment to expected configurations provides a democratization of security management.

That's not to say that IoCs are useless today, however. Vendors could continue to directly integrate IoCs into products to enable seamless detection through updates in expected patterns and behaviors. What's key here is the ability to eliminate distributed requirements to manage and deploy IoCs, a course of action which can both reduce the time to deployment and ensure the application of those requirements wherever pertinent.

Configurations and measurements that match expected values provide posture assessments along the lines of an allow-list approach. Accomplishing this at scale using attestations and remote attestation sets from the vendor obviates the need for much of the remaining IoCs shared through threat feeds. The combination of software inventory and posture assessment provided by the vendor greatly simplifies security management

for distributed organizations with or without resources while also eliminating the need for several add-on products. Numerous products already conform to a CIS Benchmark²⁸ and are available as a hardened image, after all. Additionally, tools are available to help organizations to assess these hardened images over time. Ideally, these tools will embrace a lighter touch for managing assessments in a way that makes it feasible for organizations to maintain their posture assessments.

While acknowledging the ability to automate patching and centralize testing, software vulnerabilities still require remediation. There's a window of time between when news of a vulnerability emerges and when a patch for the flaw rolls out. This is a product of software's complexity today. Attackers can therefore continue to exploit vulnerabilities if software remains unpatched and if verification of attestations does not detect an unexpected value or behavior. Software development teams' growing adoption of DevOps aids in vendors' ability to automate patching without fear of repercussions involving other software, to be sure. This reduces the need for distributed testing at each organization prior to allowing updates to systems and software.

Other methods to detect intrusions may be required in products such as endpoint assessments, tools used for detecting patterns in encrypted traffic, and relay-based screening services (e.g. domain name service and email). Any traditional in-line inspection service that relies upon access to the data portion of packets will no longer be viable due to the increased deployment of encryption.

The ideas discussed above on how industry can improve scale may not apply to all services. A need for distributed resources remains. With that said, the goal of these ideas is to improve security and reduce the deficit in a meaningful way. Legacy products, including integrated computing infrastructure in manufacturing and laboratory environments, will continue to require individual considerations, as they are essential to business operations for some organizations. Owners of industrial control systems may not replace certain devices for 20 or more years, pushing out the timeline where security can be built in. Additionally, essential security services such as authentication and authorization²⁹ do not scale well and require distributed management. This is especially true for identity proofing to receive credentials, establishing roles and access controls, as well as data classification and management.

In other words, while there is much that can be done to better secure systems and democratize security, distributed responsibilities will remain for some time. The scaling and simplification efforts mentioned above aim at reducing the security professional deficit, but they likely won't eliminate it.

²⁷ RFC5209. Network Endpoint Assessment (NEA): Overview and Requirements. P. Sangster, H. Khosravi, M. Mani, K. Narayan, and J. Tardo. June 2008. <https://datatracker.ietf.org/doc/rfc5209/>

²⁸ Center for Internet Security Benchmarks. <https://www.cisecurity.org/cis-benchmarks/>

²⁹ "Why are Authentication and Authorization So Difficult?": K. Moriarty, Center for Internet Security Blog. 2021. <https://www.cisecurity.org/insights/blog/why-are-authentication-and-authorization-so-difficult>

Summary

There are numerous discovery methods available to perform asset inventory. These include passive monitoring or network scanning to discover systems that are available on a network. In order to democratize security, it's necessary to shift left while simplifying security management. Recent advances in providing trusted infrastructure as a norm have created the opportunity for a simplified and standardized method of reporting asset inventory using built-in system capabilities to emerge. Replicating this scalable architectural pattern up the stack as industry embraces zero trust will better secure organizations with limited resources, including those across the supply chain. Adoption of built-in security that scales is a per-vendor activity. Some may struggle to secure buy-in and alignment for implementing consistent sets of standards or methods. Even so, today's threats, when coupled with zero trust, present an opportunity. The next task is to develop industry orchestration that may build on some of the existing relationships and align with other initiatives such as the Trusted Computing Group's work on assuring trusted infrastructure, assurance on the expected state of software through SBOMs, and the Linux Consortium's SigStore project.

Built-in security that scales aids both large businesses managing many thousands of systems and small organizations lacking resources to customize configurations and perform monitoring. This shift to built-in granular controls at scale also

affects the course of SolarWinds and other large-scale attacks that attempt to infiltrate numerous organizations through a single backdoor. In these cases, the attacker will need to more precisely target their objective, resulting in more focused attacks without the same level of collateral damage. While the SolarWinds attack resulted in the exfiltration of data from some organizations, it is clear that the threat actor was more interested in some targets than others by the level of access they attained after they enabled the backdoor and leaked the information. However, the impact to organizations was similar in terms of the cost to clean up and eradicate remaining vulnerabilities post-infection.

In the long term, the SolarWinds attack will continue to be a problem due to the use of exfiltrated data. For future scenarios, the costs for an attacker will be higher, as they'll need to be focused. It will be more difficult for an attacker to infiltrate a large number of organizations and remain undetected with increased detection capabilities built-in at scale on expected software and configurations on systems. When combined with zero-trust measures that reduce attacker dwell time and limit successful lateral movement, this will minimize collateral damage along with the overall scope of a successful attack.



The Center for Internet Security, Inc. (CIS®) makes the connected world a safer place for people, businesses, and governments through our core competencies of collaboration and innovation.

We are a community-driven nonprofit, responsible for the CIS Critical Security Controls® and CIS Benchmarks™, globally recognized best practices for securing IT systems and data. We lead a global community of IT professionals to continuously evolve these standards and provide products and services to proactively safeguard against emerging threats. Our CIS Hardened Images® provide secure, on-demand, scalable computing environments in the cloud.

CIS is home to the Multi-State Information Sharing and Analysis Center® (MS-ISAC®), the trusted resource for cyber threat prevention, protection, response, and recovery for U.S. State, Local, Tribal, and Territorial government entities, and the Elections Infrastructure Information Sharing and Analysis Center® (EI-ISAC®), which supports the rapidly changing cybersecurity needs of U.S. election offices. To learn more, visit CISecurity.org or follow us on Twitter: @CISecurity.

 cisecurity.org

 info@cisecurity.org

 518-266-3460

 Center for Internet Security

 @CISecurity

 TheCISecurity

 cisecurity